

LearnCode — System Architecture

Table of Contents

1. Purpose and scope
2. Context
3. Architectural overview
4. Layer 1 — Client
 - 4.1. Primary screens
 - 4.2. Client-side telemetry
5. Layer 2 — API
 - 5.1. Middleware pipeline
 - 5.2. Endpoint design
6. Layer 3 — Services
 - 6.1. The code runner
7. Layer 4 — Data
8. Data model
 - 8.1. Collections at a glance
 - 8.2. The progress table
 - 8.3. Answers never leave the server
9. AWS configuration
 - 9.1. Amplify Hosting — the client
 - 9.2. CloudFront — HTTPS for the API
 - 9.3. EC2 — the API host
 - 9.4. Lambda — the code runners
 - 9.5. DynamoDB — the progress table
 - 9.6. S3 — media
 - 9.7. Cognito — identity
 - 9.8. CloudWatch — logs and metrics
 - 9.9. IAM
10. Authentication and authorisation
11. Security posture
12. Continuous integration and deployment
13. Observability
14. Environments and configuration
15. Requirements traceability
16. Known gaps
17. Related documents

LearnCode is a full-stack interactive learning platform for programming education, built as the practical artifact of an MSc thesis at the University of Macedonia. This document describes the system as built: its layers, its data model, and the AWS configuration it runs on.

It is the **architecture** reference. Two neighbouring documents cover the rest: `DEPLOYMENT.md` is the operational runbook and holds the concrete resource identifiers, and `CHALLENGES.md` records the problems hit during construction and how they were resolved.

1. Purpose and scope

The platform sets out to bridge two things that are normally separate: the institutional flexibility of an open LMS such as Moodle or Canvas, and the interactive pedagogy of a commercial coding platform such as Codecademy or LeetCode. An institution can model its own universities, departments and semesters; a learner gets an in-browser editor that executes their code and tells them whether it was right.

Three research concepts are implemented as first-class platform features rather than as incidental UI:

Scaffolding

Progressive hints and code templates. A hint is revealed one at a time, the reveal is recorded, and it discounts the XP the lesson pays out.

Formative feedback

Automated validation against an expected output, with the error message surfaced to the learner rather than a bare pass/fail.

Self-regulated learning

Progress visualisation, notes, and lightweight gamification — XP, levels, ranks, streaks and badges.

The design intent matters when extending the system. A hint is not a UI affordance; it is a scaffolding mechanism that must be revealed progressively and tracked in the analytics, because the pilot study correlates scaffold usage with engagement.

2. Context

Three roles share one application shell, which adapts to the role claim on the authenticated user.

Role	What they do
Student	Enrols in courses, works through lessons, runs and submits code, takes quizzes, reveals hints, writes notes, messages the instructor, accrues XP and badges.
Instructor	Authors courses, modules and lessons; publishes them; reads per-lesson analytics for their own courses; answers student messages.
Admin	Manages users and their roles, publishes or unpublishes any course, maintains the institutional tree of universities and departments, and reads platform-level KPIs.

Role checks in the frontend are for presentation only. Every protected route re-validates the role server-side; a role claim from the client is never trusted.

3. Architectural overview

The system is a four-layer cloud-native application. Each layer talks only to its neighbours — a route handler never reaches into DynamoDB, and a React component never assembles a view out of five resource endpoints.

Layer 1 – Client	React 18 SPA, Vite, Tailwind, Monaco
Layer 2 – API	Express, stateless, JWT + RBAC
Layer 3 – Services	business logic, one module per domain
Layer 4 – Data	MongoDB Atlas · DynamoDB · S3

The decision to render on the client rather than server-side is deliberate: the platform is entirely behind authentication and has no SEO surface, so the usual argument for SSR does not apply.

4. Layer 1 — Client

A React 18 single-page application, built by Vite and deployed to AWS Amplify.

Concern	Choice
Routing	React Router, with route guards per role
Styling	Tailwind CSS
Editor	Monaco — the same engine as VS Code, so the editing experience is familiar
Charts	Recharts, for the student dashboard and instructor analytics
State	React context for the session; server state fetched per screen

4.1. Primary screens

Navigation is Home · Courses · Notes · Profile, with Authoring added for instructors and Admin for admins.

Student dashboard

XP, streak, completion rate, badges, enrolled-course cards with progress bars, recent activity.

Lesson page

Three panes — a tabbed left panel (Lesson / Challenge / Notes), the editor with a test-results panel in the middle, and the output console on the right. Stacks vertically on narrow screens. A non-exercise lesson keeps the reading layout plus its notes section.

Notes

Every note the learner has saved, with its course, module and lesson context, opening into an editable detail view.

Profile

Identity, level and rank, stats, the full badge gallery, a year-long activity heatmap, and enrolled or authored courses.

Admin panel

Sidebar navigation, platform KPIs, weekly-active-users chart, user management, universities and departments.

4.2. Client-side telemetry

The lesson page runs a time-on-task clock (`useTimeOnTask`). It counts only time while the document is visible and flushes increments to the API, so a tab left open unattended contributes nothing. This is the distinction between time-on-task, which the evaluation reports, and wall-clock elapsed, which an idle tab would inflate for free.

5. Layer 2 — API

A stateless Express application. Statelessness is what makes horizontal scaling possible: any instance can serve any request, because the session lives entirely in the JWT.

5.1. Middleware pipeline

Order matters, and this is the order:

1. `helmet` — security headers
2. `cors` — a single allowed origin, from `CLIENT_ORIGIN`, with credentials
3. `express.json` — body parsing, capped at 1 MB
4. `requestLogger` — structured JSON lines, so CloudWatch Logs Insights can query them (skipped under test)
5. `express-rate-limit` — 120 requests per minute per IP across `/api`
6. per-route `requireAuth`, then `requireRole([...])`
7. `attachUser` — resolves the Mongo user document from the token's `cognitoId`
8. `errorHandler` — maps thrown service errors to status codes

`trust proxy` is enabled in production, because the API sits behind CloudFront and nginx; without it the rate limiter would see one proxy IP for every caller and throttle the whole platform as if it were a single user.

5.2. Endpoint design

Endpoints are organised around what a role needs to accomplish, not around the shape of the tables. `GET /api/student/dashboard` returns the aggregated view the dashboard screen needs, in one round-trip, rather than making the client compose it from five resource endpoints.

Router	Responsibility
/health	Liveness, plus the deployed commit and timestamp
/api/auth	Sign-up completion, instructor role claim
/api/me	The profile aggregate: identity, gamification, stats, badges
/api/universities	The institutional tree
/api/student	Dashboard, activity, progress
/api/courses	Catalogue, course detail, enrolment, leaderboard
/api/lessons	Lesson delivery, hint reveal, run, submit, quiz, time-on-task
/api/notes	Learner notes
/api/messages	Student ↔ instructor threads
/api/instructor	Authoring and per-course analytics
/api/admin	User management, course publication, badges, KPIs

6. Layer 3 — Services

Route handlers are thin: parse input, call one or more services, format the response. Business logic lives in the services.

Service	Responsibility
authService	Delegates identity to Cognito. Owns role changes, which are Cognito group moves. No password ever reaches this codebase.
courseService	The course → module → lesson hierarchy, and the two lesson projections: the authoring view, and the learner view that withholds the answers.
progressService	Every learner interaction: completion, attempts, hints, runs, submissions, time on task, questions asked, note activity. Writes to DynamoDB.
gamificationService	XP accrual with the hint discount, streaks, badge award rules, and the derived level and rank functions.
codeRunnerService	Sandboxed execution of learner code, and validation against the expected output. A thin orchestrator over two adapters.
quizService	Server-side grading of quiz answer sheets against the pass mark.
profileService	The /api/me aggregate.
universityService	The institutional tree plus admin CRUD.
noteService	Learner notes, one per (user, lesson) or (user, module).
messageService	One thread per (student, course).
leaderboardService	Per-course ranking by XP earned inside that course, over a rolling window.

6.1. The code runner

This is the one service that handles genuinely untrusted input, so it gets its own treatment. Learner code is **never** executed in the API process.

Environment	Adapter
Production	AWS Lambda, one function per language. Isolation is AWS's microVM boundary.
Local development	Node vm isolates, opt-in only. Not a real sandbox — see the note below — which is why it can never be selected by default.

The adapter is chosen by environment variable at boot, and the choice fails **closed**: an unset, empty or unrecognised value resolves to Lambda, never to the in-process adapter. `vm2` is deliberately not used — it was deprecated in 2023 after repeated sandbox-escape CVEs.



An adversarial test against the deployed runner escaped the Node `vm` sandbox via `console.log.constructor('return process')()` and returned the Lambda execution role's live STS credentials. The blast radius was contained — a basic execution role, inside a microVM — but the fix, scrubbing AWS credential variables from the environment on every invocation, was ported to both runners. Static review had not found it. See `CHALLENGES.md`.

7. Layer 4 — Data

Two databases, chosen for different workloads. They are not to be collapsed into one without a strong reason.

Store	Workload	Contents
MongoDB Atlas	Read often, written rarely	Structured content and user state: the institutional tree, courses, modules, lessons, users, badges, notes, messages.
DynamoDB	Written on every interaction	Learner progress events: attempts, completions, hints, runs, time, code submissions.

The rule of thumb is **content goes to Mongo, events go to Dynamo**. A new piece of data that is read often and written rarely belongs in Mongo; anything written on every click, submission or hint reveal belongs in Dynamo.

Two properties follow from the split and are worth stating explicitly:

- There are no foreign keys between the stores. The `userId` and `lessonId` on a progress item are ids carried across the boundary by application code, not database references — which is why they are drawn dashed in the diagram.
- Level and rank are **derived, never stored**. `gamificationService.levelFromXp` computes them from `xpPoints` on every read. A stored copy would drift the moment XP was adjusted.

8. Data model

The entity diagram lives in `docs/learncode-architecture.drawio`, split across the first two of its three pages:

1. **Data model — people**: the institutional tree, the user, and badges.

- 2. **Data model — content:** courses, modules, lessons, notes, messages, and the DynamoDB progress table.
- 3. **AWS topology:** the deployment, described in the next section.

The split is for legibility — all ten entities on one page is 1700px wide, and at 100% on a portrait page the field text stops being readable. Each relationship is drawn on exactly one page, on the side that owns it; the entity at the far end appears there as a greyed stub so the line still has something to land on.

Both figures are rendered below. They are generated — `docs/generate-diagrams.js` emits the `.drawio` and the SVGs from one description of the layout, so the editable source and the figures cannot drift apart. See `docs/README.md` to regenerate them.

LearnCode data model — people and institution

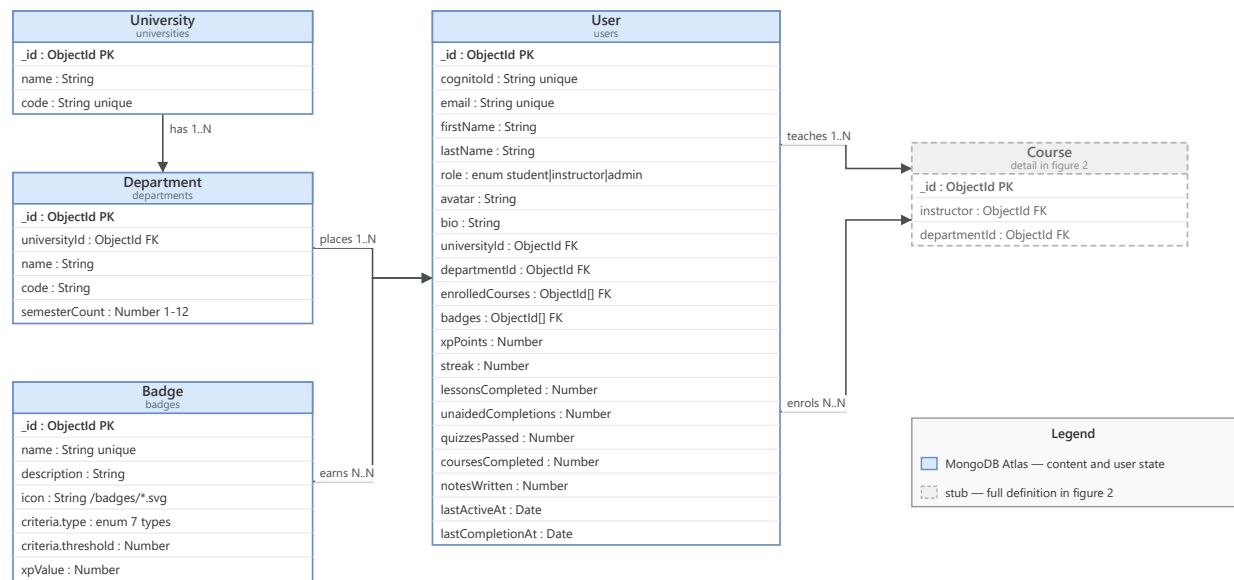


Figure 1. Figure 1 — people and institution

LearnCode data model — content and progress

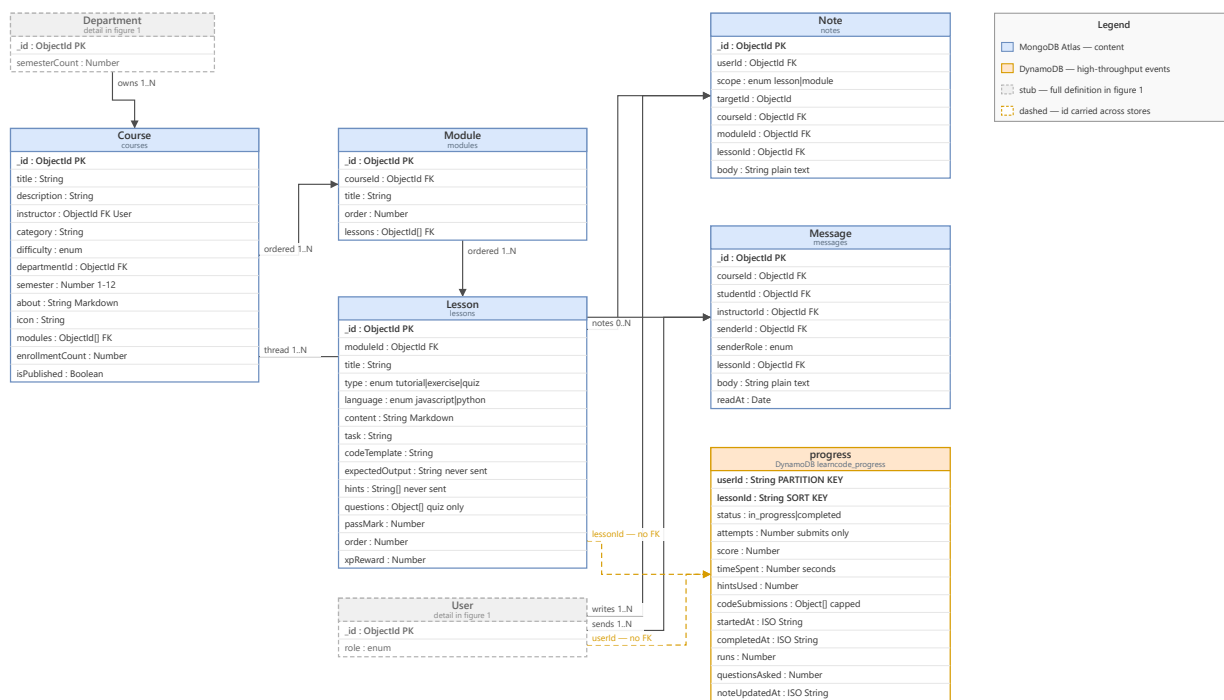


Figure 2. Figure 2 — content and progress

To edit rather than read: open `learncode-architecture.drawio` at app.diagrams.net (<https://app.diagrams.net>) (File > Open from > Device) or with the **Draw.io Integration** extension in VS Code — but change the generator and re-run it, or the next regeneration will overwrite the edit.

8.1. Collections at a glance

Collection	Notes
universities	Name and unique code. The root of the institutional tree.
departments	Belongs to one university. <code>semesterCount</code> bounds the semester a course may declare; semesters are plain integers, not documents.
users	Profile, <code>cognitoId</code> , role, institutional placement, enrolments, and the gamification counters. No password — identity is Cognito's.
courses	Metadata, instructor, department and semester, ordered modules, publication state.
modules	Ordered within a course; holds ordered lessons.
lessons	Where the scaffolding lives: Markdown content, the challenge brief, code template, expected output, ordered hints, XP reward, and — for a quiz — its questions and pass mark.
badges	Award criteria and XP value. Seven criteria types, each backed by a counter on the user document.
notes	One per (user, lesson) or (user, module). Plain text, never rendered as Markdown or HTML.
messages	One thread per (student, course). Plain text.

8.2. The progress table

A single DynamoDB table, partition key `userId` and sort key `lessonId`. The composite key answers both of the questions the application asks — "this learner's whole history" and "this learner on this lesson" — in one round-trip.

Three of its attributes exist to keep the pilot's headline metric honest. `runs`, `questionsAsked` and `noteUpdatedAt` record engagement that is deliberately **not** folded into `attempts`: only a submit is an attempt, so experimenting with the Run button cannot dilute the pass-rate denominator. All three are optional, and every reader tolerates their absence, so records written before they existed remain valid.

8.3. Answers never leave the server

`expectedOutput`, hint text, and a quiz question's `correctIndex` and `explanation` are the answers to the exercise. Shipping them to the browser would let a learner read the solution out of the network tab and pass by echoing it — corrupting exactly the pass-rate and hint-usage data the study evaluates. So:

- `expectedOutput` never leaves the server; validation happens in the runner.
- Hints are exposed as a count. The text arrives only from the reveal endpoint, which records the reveal.
- Quiz questions travel without their answer key; grading is server-side and feedback returns with the result.

9. AWS configuration

Figure 3 draws what follows.

Figure 3 — AWS deployment topology

`image::aws-topology.svg[AWS deployment topology,align="center",width="100%"]` Concrete resource identifiers live in `DEPLOYMENT.md`, deliberately in one place rather than repeated here.

Everything is in a single region, `eu-west-1`.

```
browser —https→ Amplify (React SPA)
browser —https→ CloudFront —http→ EC2:80 nginx —> node:4000
                                     |→ MongoDB Atlas
                                     |→ DynamoDB
                                     |→ Lambda runners
                                     |→ S3
                                     |→ CloudWatch Logs
```

9.1. Amplify Hosting — the client

Builds the SPA from the repository on every push to `dev` and serves it over HTTPS.

Two configuration points that are easy to get wrong:

- It must **not** be configured as a monorepo with `client` as the app root. The build installs at the workspace root; the `amplify.yml` at the repository root handles this.
- `VITE_*` variables are inlined at **build** time, not read at runtime, so changing one requires a rebuild.

The default redirect rule already provides the SPA fallback — nothing to add.

9.2. CloudFront — HTTPS for the API

The API runs on EC2 over plain HTTP; CloudFront terminates TLS in front of it, which satisfies the HTTPS-everywhere requirement without managing certificates on the instance.

Its configuration is **not** the default, and the defaults are actively wrong here because they are tuned for static content:

Setting	Value and why
Origin	The instance's public DNS name. CloudFront will not accept a bare IP.
Cache policy	CachingDisabled. The default would serve one learner's API response to another.
Origin request policy	AllViewerExceptHostHeader . The default strips the Authorization header, which would make every authenticated request fail.
Methods	All HTTP methods allowed, or writes never reach the origin.

WAF was deliberately declined: it carries a standing monthly cost, and `express-rate-limit`, helmet and Cognito already cover this threat model.

9.3. EC2 — the API host

A single `t3.micro` running Amazon Linux 2023 with an Elastic IP. nginx listens on port 80 and proxies to the Node process on 4000; the process is a systemd unit, so it restarts on failure and on boot.

Access is through **Session Manager**, not SSH. The security group admits SSH only from a fixed home IP, and browser-based EC2 Instance Connect originates from AWS ranges that the same rule blocks — so the console's default Connect tab fails while Session Manager works from anywhere.

Secrets live in a root-owned `chmod 600` environment file read by the systemd unit. They are never committed.

9.4. Lambda — the code runners

One function per language, each holding the untrusted-code boundary.

Function	Runtime	Notes
learncode-runner-js	Node.js	Registered from a built-in default name
learncode-runner-py	Python	Registered only when its function name is configured

The asymmetry is deliberate. JavaScript is the pilot language and is assumed present everywhere. Python is opt-in, so an environment without the function deployed rejects a Python submission at dispatch with a 503 that names the missing variable — rather than letting the call reach AWS and return an opaque `ResourceNotFoundException`.



Deploying a runner is not enough to make its language work. The function name must also be configured wherever the API runs. This cost real debugging time once; the refusal is now an explicit 503 rather than a bare 500.

9.5. DynamoDB — the progress table

On-demand capacity, partition key `userId`, sort key `lessonId`, encrypted at rest by default.

Analytics currently read it with a filtered `Scan`. At pilot scale — thirty learners and a few hundred items — that is acceptable and simpler than the alternative. Past that scale the fix is a global secondary index on `lessonId`, not a different aggregation.

Item size is bounded deliberately: submitted code is capped and the submission array is trimmed, because a DynamoDB item cannot exceed 400 KB and an unbounded history of submissions would eventually hit it.

9.6. S3 — media

A single bucket for media and static assets, encrypted at rest.

9.7. Cognito — identity

A user pool with three groups — `student`, `instructor`, `admin` — which map directly to the application roles. The group membership becomes a claim in the JWT.

The backend never stores a password and never issues a token. Role changes are group moves performed through the admin API, which clears stale role groups before adding the new one.

Becoming an instructor is gated by an institutional invite code held in the API's environment. Without a valid code the account is created as a student and an administrator can grant the role later; the sign-up does not fail.

9.8. CloudWatch — logs and metrics

Request logs are emitted as structured JSON lines, one per request, so they are queryable in Logs Insights rather than needing to be parsed out of free text. Secrets are kept out of log output by construction.

9.9. IAM

Two identities need the same runtime policy, and updating one does not affect the other:

Identity	Used by
An IAM user	Local development, via keys in the developer's environment file
An IAM role on the instance	The deployed API

The policy scopes `lambda:InvokeFunction` to explicit function ARNs rather than a wildcard. The consequence is worth knowing before it bites: **every new language runner requires widening the policy in both places**, or the API gets `AccessDeniedException` while a Console test of the same function passes.

10. Authentication and authorisation

1. The client authenticates against Cognito and receives a JWT.
2. Every protected route runs `requireAuth`, which validates the token's signature, issuer and expiry against the pool's published keys.
3. `requireRole([...])` then checks the group claim against the permission matrix for that route.
4. `attachUser` resolves the Mongo user document from the token's `cognitoId`.

Authorisation is enforced in middleware, not in handlers, so a new route cannot accidentally omit it by forgetting an `if`. Ownership checks that middleware cannot express — "is this your course?" — live in the services and throw a 403 rather than returning someone else's data.

11. Security posture

Control	Implementation
Transport	HTTPS end to end. TLS terminates at CloudFront and at Amplify.
Tokens	Cognito-issued and Cognito-expired, refreshed by the client SDK.
Input validation	Server-side on every endpoint; ids are validated before reaching Mongo, so a malformed id is a 400 rather than a cast error surfacing as a 500.
RBAC	Middleware, ahead of every handler.
Rate limiting	120 requests per minute per IP across /api.
Encryption at rest	Atlas and DynamoDB defaults; S3 bucket encryption.
Untrusted code	Executed only in Lambda in production, never in the API process.
Secrets	Host environment file, chmod 600, never committed. CI uses OIDC rather than stored AWS keys.
Answer leakage	Expected outputs, hint text and quiz answer keys never reach the browser.
Mass assignment	Writable fields are picked explicitly on instructor and admin endpoints rather than spread from the request body.

Changes touching authentication, input handling or code execution are checked against the OWASP Top 10 before merging.

12. Continuous integration and deployment

Pushing to `dev` is the whole deployment process.

```
push to dev
├─ GitHub Actions
│   ├── Server – lint & test           } both must pass
│   ├── Client – lint & build         }
│   └─ Deploy API to EC2
│       ├── assume IAM role via GitHub OIDC (no stored keys)
│       └─ SSM Run Command → deploy script on the instance
└─ Amplify rebuilds the client independently
```

The Lambda runners are deployed manually, on purpose: they change rarely, and an automated path would add a deployment surface for the one component that executes untrusted code.

Three traps are documented in `DEPLOYMENT.md` and worth repeating:

- An SSM Run Command session has no `$HOME`, unlike an interactive Session Manager shell. Anything assuming one — `git config --global`, npm's cache directory — fails there and only there.
- nginx refuses a configuration whose `server_name` is longer than its default hash bucket, which an EC2 public DNS name comfortably exceeds.
- **A red deploy job does not mean the code did not ship.** Install and restart happen before verification, so a failure in the verification step leaves the new commit live. `/health` reports the running commit; that is the ground truth, and it is the first thing to check.

13. Observability

`GET /health` returns liveness, Mongo connectivity, uptime, and the deployed commit and timestamp. Comparing its `commit` against the branch is the fastest way to establish what is actually running.

Application logs are structured JSON in CloudWatch. Uptime for the pilot is targeted at 99.5%.

14. Environments and configuration

Configuration precedence is **real environment variables first**, then the server's environment file, then the repository root's.

This ordering was a bug fix, not an accident. The loader previously applied the file with override semantics, so a developer's checked-out file beat the platform's injected variables —

`NODE_ENV=production` silently resolved to `development`, and no platform variable could take effect. The runner adapter now also fails closed, so a mis-set variable cannot quietly select the in-process sandbox in production.



Local development and production currently share one MongoDB database. Anything created while testing locally — courses, lessons, notes, messages, role changes — is production data the moment the matching code deploys. Splitting out a separate development database is the obvious hardening step and has not been done.

15. Requirements traceability

Ref	Requirement	Where it lives
FR1	Authentication and RBAC	Cognito, <code>requireAuth</code> + <code>requireRole</code>
FR2	Interactive editor with execution and validation	Monaco, <code>codeRunnerService</code> , Lambda
FR3	Course → module → lesson hierarchy	<code>courseService</code> , Mongo
FR4	Scaffolded hints and formative error messages	<code>lessons</code> collection, reveal endpoint
FR5	XP, badges, streaks, progress	<code>gamificationService</code>
FR6	Analytics dashboard	<code>progressService.getCourseAnalytics</code> , Recharts
FR7	Instructor course creation	<code>/api/instructor</code>
FR8	Admin tools	<code>/api/admin</code>
NFR1	Responsive desktop and mobile	Tailwind breakpoints; panes stack on narrow screens
NFR2	Horizontally scalable	Stateless API; session lives in the JWT
NFR3	Primary interactions under 3 s	Aggregated endpoints; warm Lambda invocations measured in tens of milliseconds
NFR4	HTTPS/TLS everywhere	CloudFront and Amplify
NFR5	WCAG 2.1 AA	Partially — see gaps below
NFR6	99.5% uptime during the pilot	<code>systemd</code> restart, CloudWatch

16. Known gaps

Stated plainly, because an architecture document that only describes intent is less useful than one that says where the system falls short.

Gap	Detail
No client test suite	CI lints and builds the frontend but runs no tests. The backend has full unit and integration coverage; the frontend has none.
WCAG 2.1 AA unaudited	NFR5 has never been formally audited. Individual measures are in place — prefers-reduced-motion is honoured, status regions are announced, controls are labelled — but no audit has been run against the standard.
Shared development database	See the warning above.
Analytics scan	Course analytics use a filtered Scan, which is fine at pilot scale and not beyond it.
No admin activity log	Administrative actions are not recorded to an audit trail.
Mobile untested on device	The layout is responsive and has been exercised in a browser, but not on real hardware.

17. Related documents

Document	Contents
DEPLOYMENT.md	The runbook: deploy steps, IAM policies, environment variables, the pre-pilot checklist, CI/CD setup and troubleshooting. Holds the concrete resource identifiers.
CHALLENGES.md	Problems encountered during construction and how they were resolved, by sprint. The source for the thesis's implementation chapter.
SOLUTION_SKETCH.md	The original design sketch and sprint roadmap.
REFACTOR.md	The pre-deployment hardening review and its implementation record.
docs/generate-diagrams.js	Emits the editable .drawio and the three SVG figures from one layout description.
docs/README.md	How to regenerate the diagrams, the HTML and the PDF.

Last updated 2026-09-06 17:12:17 +0300